

RDP BRUTE-FORCE DETECTION POC

PREPARED BY:

Rohan Teja

August 2026

INTRODUCTION

This report documents a proof-of-concept exercise testing whether Wazuh detects an RDP brute-force attack against a Windows 10 endpoint. Hydra was run from a Kali attacker VM against the RDP service, first against Wazuh's default ruleset, then against two custom correlation rules written for this case.

It covers the attack run, the default detection baseline, the custom rule configuration, validation that the rules fire, the raw event data behind the alert, and the troubleshooting hit along the way — mainly Hydra's RDP module refusing connections until the attack parameters were tuned.

Lab Environment

Machine	Role	Operating System	Purpose
DESKTOP-TDOGRJA	Target / Victim	Windows 10 x64	RDP endpoint under attack; Wazuh agent installed
Wazuh Manager	SIEM	Ubuntu Server (Docker, single-node)	Log correlation, custom rule matching, alerting
Kali Attacker	Attacker	Kali Linux 2026.2	Hydra-based RDP brute-force tool

1. MITRE ATT&CK MAPPING

Tactic	Technique	Notes
Credential Access	T1110 – Brute Force	Wazuh's rule metadata tags rules 100100 and 100101 under this technique
Credential Access	T1110.001 – Password Guessing	Hydra ran a fixed password list against a single known username (Victim) over RDP

2. RUNNING THE ATTACK

Hydra targeted the RDP service directly:

```
hydra -l Victim -P pass.txt rdp://192.168.142.130
```

The first several runs failed outright — Hydra's RDP module reported connection errors instead of logon failures (see Troubleshooting). Once that was resolved, the attack generated a string of Windows Event ID 4625 failures on the target.

```
(kali@kali): ~/Desktop
$ hydra -l Victim -P pass.txt rdp://192.168.142.130
Hydra v9.7 (C) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore Laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-22 16:06:47
[WARNING] rdp servers often don't like many connections, use -M 1 or -W 3 to reduce the number of parallel connections and -W 1 or -W 3 to wait between connection to allow the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 5 login tries (1:1/p/s), ~3 tries per task
[DATA] attacking rdp://192.168.142.130:3389/
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-22 16:06:51

(kali@kali): ~/Desktop
$ nano pass.txt

(kali@kali): ~/Desktop
$ hydra -l Victim -P pass.txt rdp://192.168.142.130
Hydra v9.7 (C) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore Laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-22 16:07:26
[WARNING] rdp servers often don't like many connections, use -M 1 or -W 3 to reduce the number of parallel connections and -W 1 or -W 3 to wait between connection to allow the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 12 login tries (1:1/p/12), ~3 tries per task
[DATA] attacking rdp://192.168.142.130:3389/
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
The session file /hydra.restore was written. Type "hydra -R" to resume session.
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-22 16:07:31
```

Figure 1 — Hydra RDP brute-force attempts against 192.168.142.130, including the early connection failures before the retry.

3. BASELINE DETECTION (DEFAULT RULES)

Before any custom rule was added, Wazuh's default ruleset already caught the failed logons individually: rule 60122 (Logon Failure – Unknown user or bad password, level 5) fired on every attempt, and rule 60204 (Multiple Windows Logon Failures, level 10) fired once the failure count crossed Wazuh's built-in threshold. Over a 24-hour window this produced 515 hits — accurate, but noisy, and not labeled as a brute-force verdict on its own.

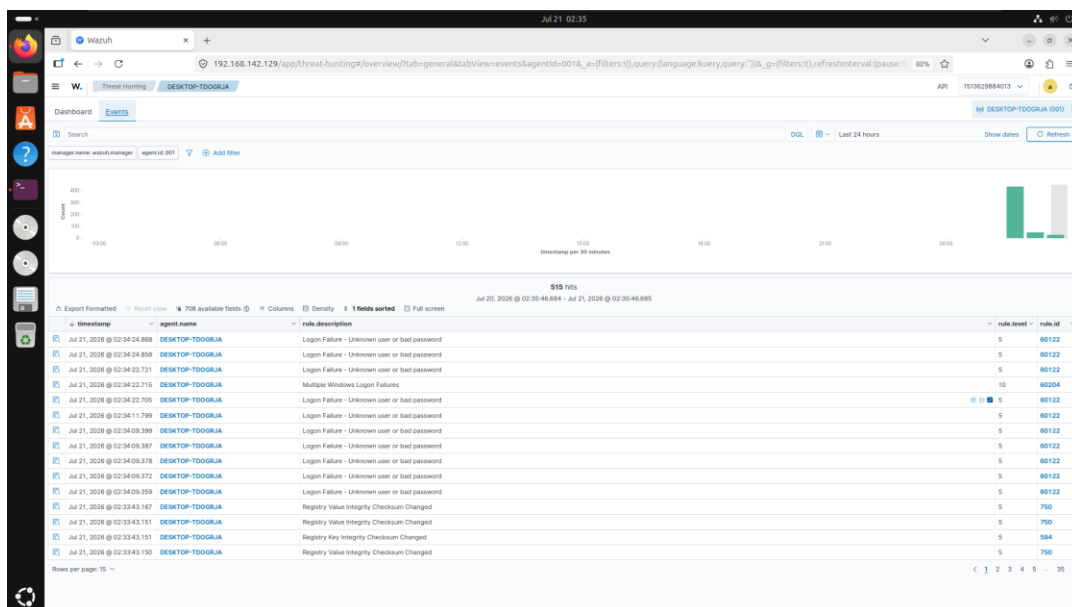


Figure 2 — Default rule hits (60122, 60204) before the custom rule was added.

4. WRITING THE DETECTION RULES (WAZUH)

Two rules were added to local_rules.xml on the Wazuh manager to turn the raw failures into an explicit brute-force verdict.

```
<group name="local">
  <rule id="100100" level="15">
    <if_sid>60204</if_sid>
    <description>Custom: RDP Brute Force Detected</description>
  </rule>
</group>
```

```
rohangrohan-Vmware-Virtual-Platform:~/wazuh-docker/single-node$ docker exec -i single-node-wazuh.manager-1 sh -c 'cat >/var/ossec/etc/rules/local_rules.xml' <<'EOF'
<group name="local">
  <rule id="100100" level="15">
    <if_sid>60204</if_sid>
    <description>Custom: RDP Brute Force Detected</description>
  </rule>
</group>
EOF
rohangrohan-Vmware-Virtual-Platform:~/wazuh-docker/single-node$ docker exec -it single-node-wazuh.manager-1 cat /var/ossec/etc/rules/local_rules.xml
<group name="local">
  <rule id="100100" level="15">
    <if_sid>60204</if_sid>
    <description>Custom: RDP Brute Force Detected</description>
  </rule>
</group>
```

Figure 3 — Rule 100100 added on the Wazuh manager container and confirmed in local_rules.xml.

Rule 100100 escalates on top of the existing 60204 multiple-failure rule, at level 15, tagged rdp in its group list. A second rule narrows the same behavior further, correlating failures by source IP instead of by account:

- **ID:** 100101
- **Level:** 15
- **Description:** Custom: Windows Brute Force (8 failed logons from same IP)
- **Groups:** attack, bruteforce, authentication, local
- **Frequency:** 8
- **Timeframe:** 240 seconds
- **if_matched_group:** authentication_failed
- **same_field:** win.eventdata.ipAddress
- **MITRE Technique:** Brute Force (T1110)
- **MITRE Tactic:** Credential Access

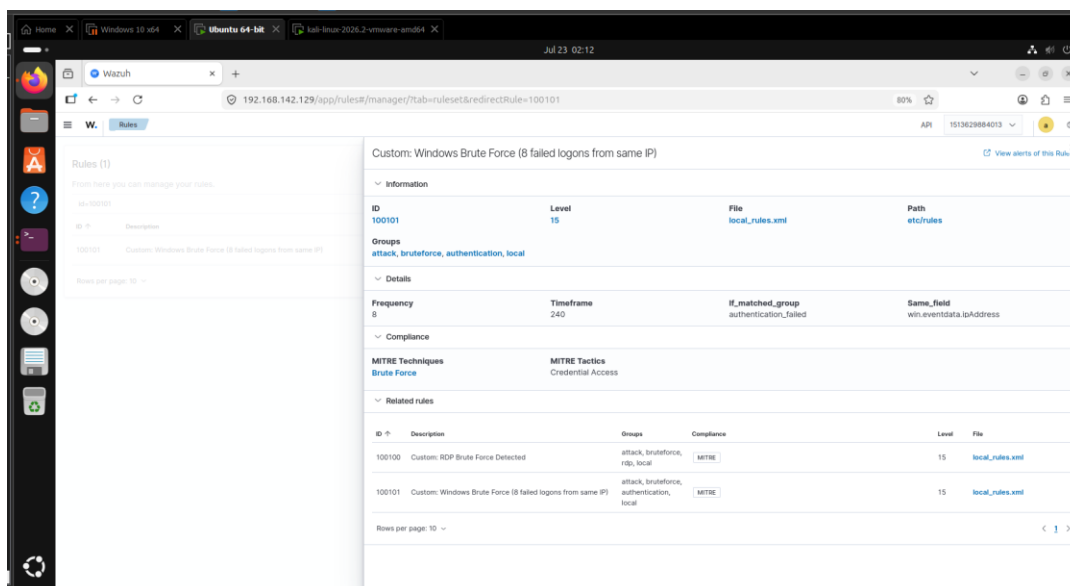


Figure 4 — Rule 100101 detail in Wazuh's Rule Manager, showing the frequency/timeframe correlation and its MITRE ATT&CK tags.

5. VALIDATING DETECTION

Re-running the Hydra attack with both rules active produced two escalated alerts alongside the usual logon-failure noise.

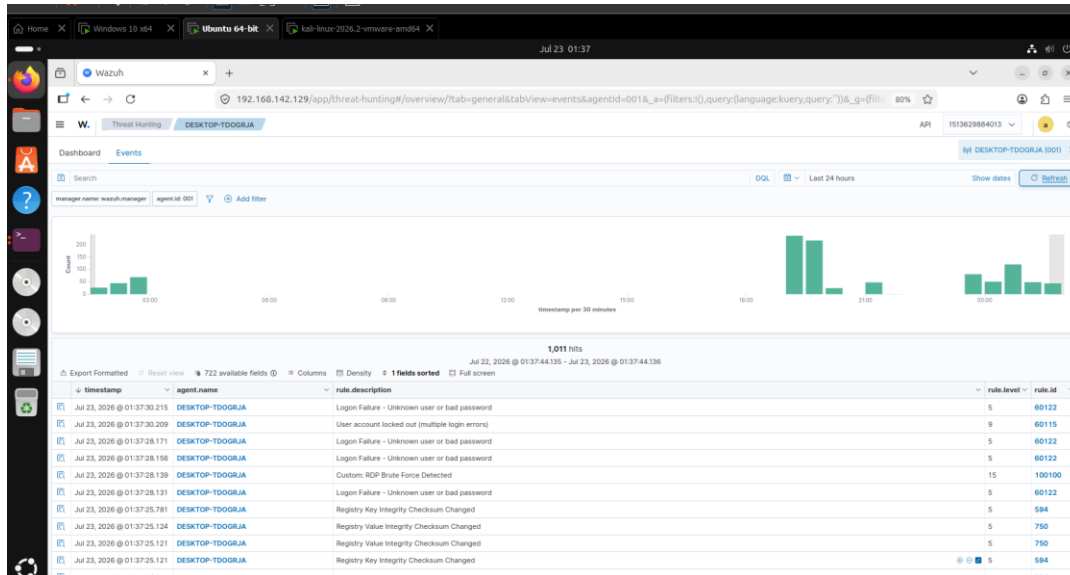


Figure 5 — Rule 100100 (level 15, Custom: RDP Brute Force Detected) firing alongside default rules 60122 and 60115.

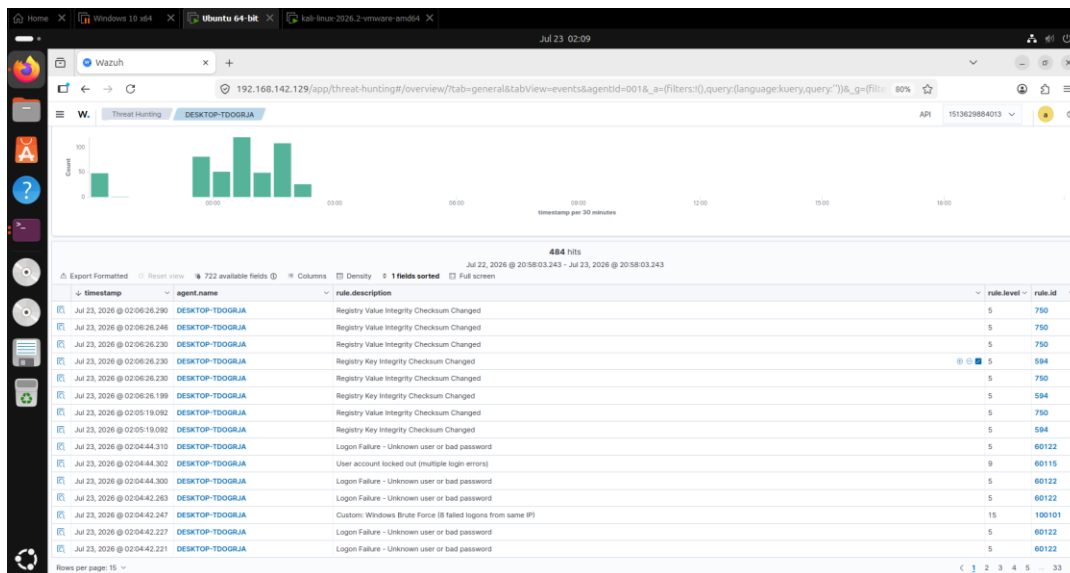


Figure 6 — Rule 100101 (level 15, 8 failed logons from same IP) firing after the frequency threshold was reached.

Visualizing Alerts in Wazuh Dashboard

1. Log in to the Wazuh dashboard.
2. Navigate to Threat Hunting.

3. Filter using: rule.id:(100100 OR 100101)

6. EVENT DETAIL (WINDOWS SECURITY LOG)

Behind every one of these alerts is the same underlying Windows Security event.

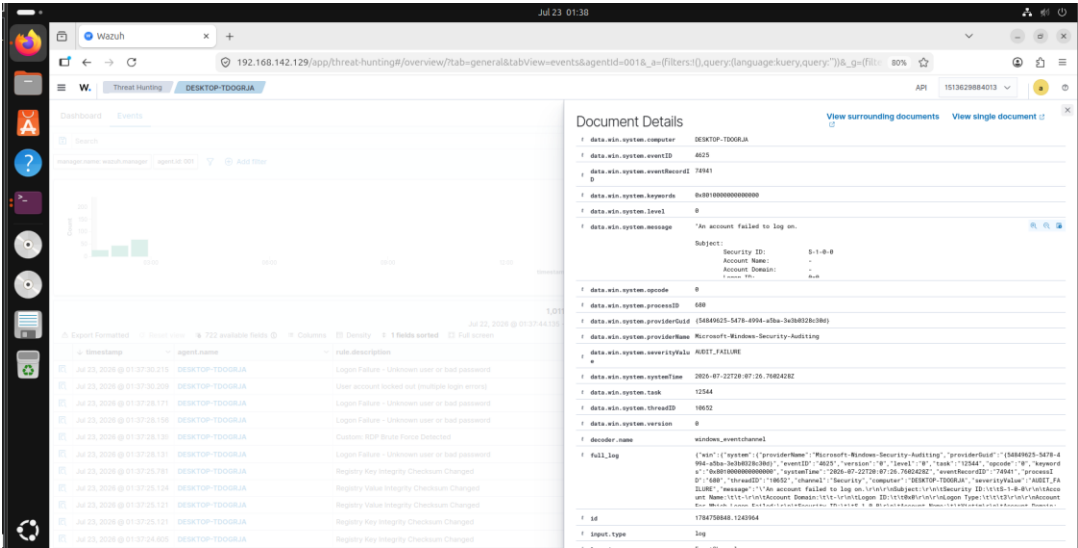


Figure 7 — Event ID 4625 detail, decoded by Wazuh's windows_eventchannel handling.

Field	Value
Event ID	4625
Provider	Microsoft-Windows-Security-Auditing
Message	An account failed to log on.
Computer	DESKTOP-TDOGRJA
Severity	AUDIT_FAILURE

7. TROUBLESHOOTING

Hydra's RDP module refusing connections

The first attack runs didn't produce any Windows-side failures at all. Hydra returned connection errors instead of logon attempts:

```
freerdp: The connection failed to establish
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
```

Hydra's own warning explains why: the RDP module is marked experimental and doesn't tolerate many parallel connections — the default of 4 tasks was enough to get attempts refused before they reached the login prompt.

Dropping the task count (-t 1 to -t 4) and adding a wait between attempts (-W 1 to -W 3), as Hydra's warning suggests, fixed it. A leftover hydra.restore file from the failed runs also had to be cleared before Hydra would

start a fresh session instead of trying to resume the broken one. After that, Hydra completed all 12 login attempts and Windows logged a 4625 event for each.

8. OUTCOME

Wazuh's default rules already caught every individual failed RDP logon; what they didn't do was mark the pattern as a brute-force attack. Rules 100100 and 100101 close that gap — one escalating on the existing multiple-failure rule, the other correlating failures by source IP within a 240-second window — and both mapped cleanly to MITRE ATT&CK T1110 under Credential Access. The one real snag was on the attacker side, not the detection side: Hydra's RDP module needed its concurrency tuned down before it could even generate the traffic to detect.